

ÉCOLE NATIONALE D'INGÉNIEURS ABDERHAMANE BABA TOURÉ · BAMAKO

Fiche technique

Un middleware local PHP et un MLP local pour repérer les tentatives d'injection SQL, avec un mode d'observation et une console de revue.

MVP local

SQLi uniquement

Inférence locale

Stade de validation

Démonstrateur local. Aucun pilote client, audit externe, test d'intrusion indépendant ou résultat de performance en charge n'est revendiqué.

ÉQUIPE INDIQUÉE DANS LE DOSSIER SOURCE

Sékou Doucouré, porteur

Adama Nakoun Fané, collaborateur

Noms, rôles et consentement à confirmer avant soumission.

PÉRIMÈTRE ET ARCHITECTURE

Détection SQLi dans un environnement PHP.

Le logiciel examine les entrées d'une requête avant leur traitement, combine règles heuristiques et MLP local, puis journalise une décision expurgée dans une console administrateur.

Entrée Requête HTTP et limites d'entrée	Règles PHP Normalisation et signatures SQLi	MLP local Analyse bornée des valeurs candidates	Décision Observation ou blocage selon la politique	Console Événement et explication locale
---	---	---	--	---

Élément	Implémentation du dépôt
Filtre applicatif	PHP 8.4, Apache; moteur heuristique et middleware d'entrée.
Classifieur	MLP scikit-learn v2, 37 caractéristiques, architecture 37→128→64→32→1, seuil fixe 0,75. Le score n'est pas une probabilité calibrée.
Service d'inférence	Python 3.13, Flask et Waitress sur interface locale/réseau interne.
Base de démonstration	MariaDB, accès `mysqli` paramétrés dans la boutique fictive.
Journalisation	JSONL expurgé, sans conserver les valeurs brutes des paramètres; métadonnées réseau et de route toujours à protéger.
Déploiement	Docker Compose local ou Wamp; le port web est publié sur la boucle locale par défaut dans Compose.

Fonctions présentes

Console de supervision; laboratoire qui n'exécute pas le SQL; MFA administrateur; protections CSRF et limites de débit/taille; mode observation configurable; export local et transfert SIEM facultatif.

Fonctions hors périmètre

Pas de détection XSS, LFI, audit de mots de passe ou couverture OWASP complète. Aucun assistant LLM n'est présent : l'explication est locale et déterministe.

Défense en profondeur

Conserver les requêtes préparées et les contrôles applicatifs. CyberShield AI ne constitue pas une preuve qu'une entrée est sûre et ne remplace pas la correction d'une requête vulnérable.

Le mode observation concerne les décisions SQLi. Les contrôles opérationnels d'accès IP, de débit et de taille continuent de s'appliquer.

MESURES REPRODUCTIBLES

Benchmarks publics, interprétés avec prudence.

Évaluation	Résultats	Portée
HttpParamsDataset · split de test 10 051 valeurs `norm`/`sqli`; entraînement sur un split distinct de la même famille.	F1 0,999170 Précision 0,999723 Rappel 0,998618 TN 6 433 / FP 1 FN 5 / TP 3 612	Test en domaine public; aucune garantie de performance sur trafic client.
SR-BH 2020 · MLP seul 775 506 lignes SQLi ou strictement normales sur un honeypot WordPress pendant 12 jours.	F1 0,862153 Précision 0,865160 Rappel 0,859167 Spécificité 0,936180	Capture unique. Environ 6,4 % de faux positifs parmi les normales de ce corpus.
SR-BH 2020 · jeu hybride Simulation de la politique middleware sur la même capture.	F1 0,860560 Précision 0,865092 Rappel 0,856075 Spécificité 0,936372	Mesure de développement; présélection décidée après examen de la capture. Pas de mesure de latence HTTP.

20 105

exemples d'entraînement `norm`/`sqli`

1

honeypot représenté dans SR-BH

0

pilote client documenté

Les anciens chiffres ne sont pas confirmés

Le jeu de 10 000 requêtes, le F1 0,988, les faux positifs à 0,5 %, les faux négatifs à 0,1 %, les 98 % sous 100 ms et les tests SQLmap/Burp/Apache Benchmark du PDF antérieur ne sont pas étayés par les fichiers présents dans le dépôt.

Prochaines validations

Conduire un pilote autorisé sur une copie d'application, en mode observation. Utiliser des sondes contrôlées non destructives, un échantillon de revue aveugle étiqueté avec preuve indépendante, des critères acceptés avant le test et un rapport approuvé par l'hôte.

Mesurer les faux positifs, le rappel sur les sondes contrôlées, la latence de bout en bout p50/p95, le taux d'erreurs et la consommation sur une machine identifiée. Commander ensuite une revue de sécurité indépendante sur un environnement isolé.